

BlockNotice

거절된 출금은 트랜잭션이 되지 않습니다.

그래서 기록이 기관 쪽에만 남습니다.

오프체인 출금 판단의 서명 영수증을 요청자에게 돌려주고,
기관이 서명한 약속이 지켜졌는지를 **기관 서버 없이** 확인합니다.

저장소: github.com/kimsabin725/blocknotice · 모든 수치는 `npm run demo` 한 명령으로 재현됩니다

승인은 체인에 남고, 거절은 아무 데도 안 남는다

출금이 **승인**되면 트랜잭션이 남습니다. 누구나 봅니다.

출금이 **거절·보류**되면 기관의 내부 DB 말고는 어디에도 안 남습니다.

나중에 기관이 「그런 요청 없었다」거나 「사유는 이랬다」고 말을 바꾸면, 이용자에게는 반박할 근거가 없습니다.

가상자산이용자보호법은 기록·통지 의무를 만들었지만, 그 기록이 지켜졌는지 제3자가 확인할 형식은 비어 있습니다.

실행 전(before execution)에 일어나는 보안 문제

체인에 실행 결과가 남기 전, 「누가 언제 무엇을 판단했는가」가 한쪽에만 있습니다.

이건 암호학 문제가 아니라 **증거 비대칭** 문제입니다. 기관은 다 알고, 이용자는 아무것도 증명 못 합니다.

BlockNotice가 하는 일: 그 비대칭을 서명 영수증 + 공개 커밋으로 대칭에 가깝게 만듭니다.

누구를 위한 것인가 — 먼저 좁힙니다

1차 장면은 기관 커스터디입니다

달는 사람

기관 고객. 이미 외부 지갑·HSM으로 서명하고, 커스터디 계약에 SLA가 있어 **증빙을 계약으로 요구할 힘**이 있습니다.

출금 주소에 서명할 수 있는 외부 지갑 보유자.

조건부

거래소 앱 내부 이용자는 passkey가 **거래소 밖**(단말·OS)에 있을 때만. 거래소가 키를 대신 보관하면 보증은 전부 무효입니다.

안 달는 사람

국내 거래소 이용자 대부분. 커스터디일이라 키가 없습니다.

이들에게 달으려면 **거래소 밖 키가 먼저**입니다. 그 전엔 남는 경로가 소송뿐입니다.

이걸 첫 장에 두는 이유 — 「모든 이용자를 위한 것」이라고 말하면 가장 먼저 무너지는 곳이 여기입니다.

누가, 무엇을 가지고, 무엇을 시도하는가

행위자	가진 능력	시도할 수 있는 공격
기관 (결정자)	로그 서명키, 앵커키, DB, 서버, 메모 관찰	기록 누락·삭제·수정·백데이트 / 사유 사후 교체 / 영수증 보류 / 기한 자가 연장 / 늦은 응답으로 지각 은폐
요청자	자기 키, 받은 영수증	없던 의무 날조 / 남의 영수증으로 기관 괴롭히기 / 조작된 묶음으로 허위 고발
제3자	자기 도메인·자기 키	통째로 위조한 묶음을 진짜처럼 제시
외부 관찰자	로그·앵커·공개 제출 열람	대상·금액·주소 식별 (실패) / 건수 추정 (부분 성공)

비가정: 로그키·앵커키 동시 유출, 체인 재구성, 요청자 = 결정자, 그리고 오프체인 전달 자체의 증명(존재하지 않습니다).

어떻게

서명 영수증 + 컨트랙트가 직접 계산하는 공개 로그

요청자 —서명 요청(EIP-712)+HPKE 봉투→ 기관

← AcceptedReceipt —————

(기록 기한 + 요청자 바인딩, REQ 리프 기록
기관 서명)

← DecisionRecord —————

(암호화 전달, 기관 서명) DEC 리프 기록

공개 로그 : append-only 머클 트리(깊이 32)
루트는 제출받지 않고 컨트랙트가 계산

검증기 : 파일 + 공개 로그 루트만으로 판정
기관 접속 0회 (실측)

- 루트를 제출받지 않습니다. 리프를 받아 컨트랙트가 계산합니다. 기관이 자기가 만들지 않은 트리의 루트를 올릴 수 없습니다.
- 기한은 기관의 시계가 아니라 체인이 본 블록에서. 영수증이 인용한 앵커의 실제 블록 + 등록된 간격을 컨트랙트가 다시 계산해 대조합니다.
- 영수증 사본은 자격이 아닙니다. 이름이 적힌 요청자만 챌린지를 열 수 있고, 그 바인딩에 기관이 서명합니다.
- 컨트랙트는 해시만 저장합니다. 요청 내용·통지문·사유를 모릅니다.

「모르겠다」와「위반이다」를 섞지 않습니다

보증합니다

- 기록 무결성 — 영수증 서명과 공개 커밋의 일치. 사후 교체 탐지.
- 접수 책임 — 서명한 기록 기한이 지켜졌는가.
- 독립 제출 — 영수증 없이도 공개 경로에 제출 사실을 남김.
- 기관 접속 0회 — 검증 중 나간 HTTP 호출을 세어서 보고. 상수가 아니라 실측.

보증하지 않습니다

- 비공개 사유의 진실성 — 커밋은 교체를 탐지할 뿐.
- 기관이 아무에게도 안 알린 판단 — 존재를 발견 못 함.
- 오프체인 전달 — 어떤 컨트랙트도 증명 못 함. 영수증 없는 공개 제출은 중립 기록.
- 완전성 — 각자 자기 항목만. 전체는 근사.
- 법적 강제력 — 체인은 의무를 만들지 않음.

판정 5분류: CONFIRMED · NOT_DUE · OBLIGATION_UNMET · UNVERIFIABLE · OUT_OF_SCOPE — 「아직」과 「모름」은 위반이 아닙니다.

검증 결과 — 전부 `npm run demo` 한 명령으로 재현

공격 11개 전부 탐지, 정상 5개 오탐 0

11/11

공격 탐지

0

오탐 (정상을 위반으로)

93

검사 총계 — Solidity 31 · TS 46 ·
시나리오 16

각 장면은 돌기 전에 결론을 선언합니다. 기대값이 검사 항목 id와 상태를 직접 지목하므로, 검증기가 조용해서 통과하는 일이 없습니다.

오탐 0이 탐지 11만큼 중요합니다. 정직한 기관을 위반으로 찍는 도구는 아무도 안 씁니다.

기한 경과 장면은 로컬 체인에서 블록을 당겨 시연했습니다. 공개 테스트넷에는 실제로 일어난 것만 있습니다. 물을 섞지 않습니다.

공격

접수 누락 · 결정 누락 · 사후 조작 · 가짜 루트 · 통째 위조 · 등록 없음 · 무응답 · 늦은 기록 · 남의 영수증 · 기한 자가 연장 · 없는 앵커

정상

제때 처리 · 기한 전 · ACK 없음 · ACK 바인딩 · 중립 공개 제출

우리 말을 믿지 말고 직접 확인하세요

네트워크	컨트랙트	비고
Sepolia (11155111)	<code>0x6841393c82c984edbc6eca822dab7028cc6f9a94</code>	2026-09-30 종료 예정 — 데모데이 다음 날
Hoodi (560048)	<code>0xa9d34bb52d8015159a44ee1f0f9838b3c228792a</code>	같은 바이트코드 7,924 B. 종료 대비 미리

`npm run check:deployment`

chainId · 런타임 바이트코드 · 서비스 등록 · 기관 서명자 ·
프로필 해시를 공개 **RPC에서 다시 읽어** 저장소 기록과 대조.
하나라도 어긋나면 0이 아닌 코드로 종료. **.env 없이** 클론만
하면 됩니다.

가스 (Foundry 실측)

`appendBatch` 64장 1,576,428 ·
`challengeAccepted` 평균 104,714 · `respond`
79,925 · `finalize` 26,586. 배포 8,325 B.

「Arbitrum delayed inbox와 뭐가 다르죠?」

발명이 아니라 이식입니다. 롤업은 프로토콜이 포함을 강제합니다. 오프체인 결정 서비스에는 그 강제가 없습니다.

- 포함 여부를 롤업 상태 대신 **머클 앵커**로 판정합니다.
- 강제가 없는 자리를 「**기관이 서명한 기한**」+ 「**체인이 본 앵커에서의 역산**」으로 채웠습니다.
- CT(RFC 6962)와 달리 여기선 **안 올리는 게 이득**이라, 안 올린 사실을 요청자가 자기 영수증으로 증명하게 만들었습니다.

기술 델타는 하나입니다

나머지 셋 — 2단 사유 공개(약관 번호 평문 + 세부 커밋),
분류표 기반 판정 상한, ACK 내장 — 은 **규제 매핑**입니다.

독창성이 아니라 문제 정의·확장성 쪽에 놓습니다.

안 되는 것, 안 만든 것

- **요청자 = 결정자**는 못 잡습니다. 자기 지갑·같은 법인.
- **영수증 보류**는 못 막습니다. 성실히 앵커하며 영수증만 안 주면 위반 0건. 수수료 세금으로 퇴화할 뿐입니다.
- **경제적 강제총(stake-fee)**은 설계만. 지금 컨트랙트엔 예치금도 수수료도 없습니다.
- **serviceld**는 **선착순**. 남의 영수증 위조는 불가하지만 이름은 뺏깁니다.
- **앵커키 보유자의 역사 분기** — consistency proof 온체인 검증 미구현. 2-of-3 멀티시그 권고.
- **에폭 size 증가분**이 건수를 흘립니다.
- **키 회전 미구현**. 요청자 키 분실 = 자기 증거 상실.
- **서명된 타임라인은 양날**. 기관 방어 증거이자 소송의 원고 증거. 법무팀이 거부할 수 있습니다 — 기술로 못 풀니다.

인접 블록 재조직으로 판정이 뒤집힐 수 있어 검증기는 확정된 앵커만 씁니다. 컨트랙트는 이걸 막지 못합니다.

93개 검사, 두 체인, 한 명령

- 거절된 출금의 증거 비대칭을 서명 영수증 + 공개 커밋으로 줄입니다.
- 공격 11개 탐지, 오탐 0. 전부 `npm run demo` 로 재현.
- Sepolia · Hoodi 배포, `.env` 없이 되읽기 검증.
- 보증하지 않는 것과 한계 8개를 먼저 적었습니다.

새로 구현한 범위 · AI 사용

이 기간에 새로 구현: 컨트랙트 전체, EIP-712·HPKE 영수증, 머클 로그, 독립 검증기, 시나리오 하니스, 보고 화면.

구현은 Claude Code(Claude Opus 5)와 함께 했습니다.
설계 판단·위협 모델·한계의 취사선택은 사람이 했습니다.